

# La solución requiere separar tres planos.

La automatización efectiva en seguridad combina razonamiento, orquestación y ejecución bajo identidades y controles explícitos. Cada plano tiene responsabilidades distintas y límites definidos.



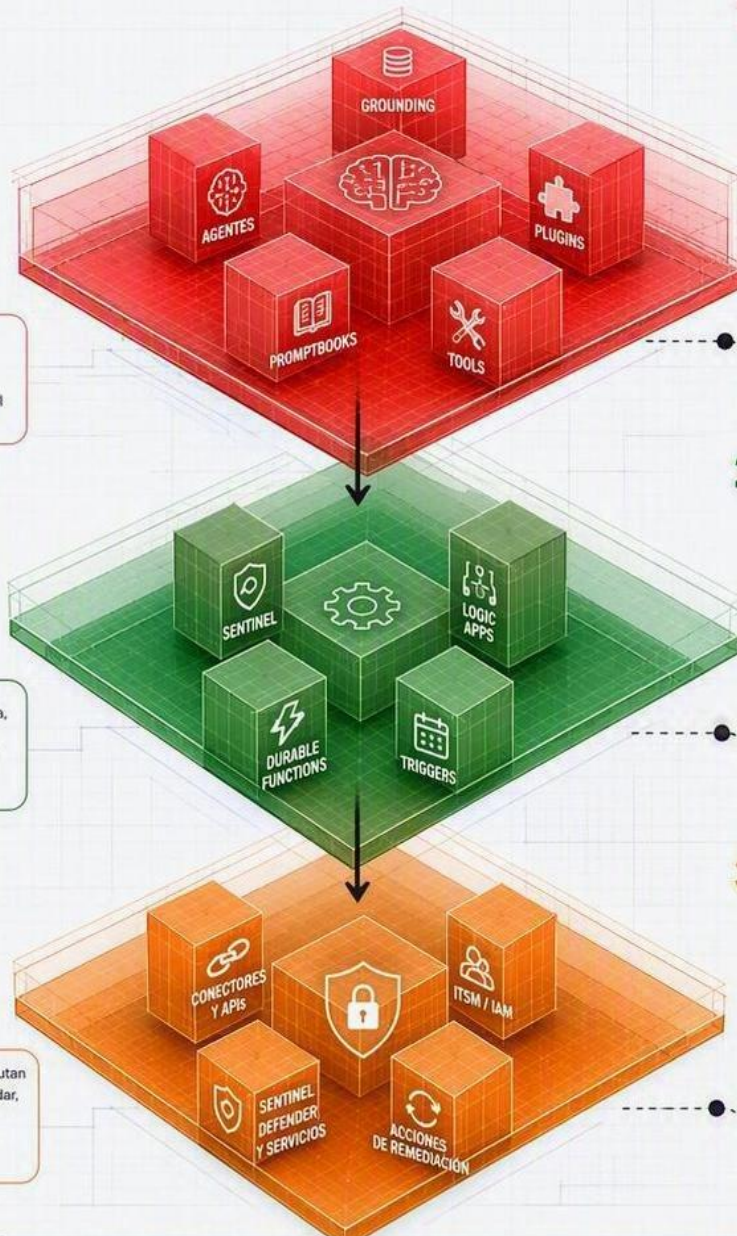
## PROPÓSITO

Convertir la inteligencia del agente en acciones seguras, auditable y recuperables.

El agente aporta interpretación, planificación y selección contextual de herramientas.

El workflow orquesta, aplica políticas y mantiene el control operativo.

Las acciones se ejecutan solo después de validar, aprobar y autorizar, con identidades de mínimo privilegio.



## 1 PLANO DE RAZONAMIENTO

Interpretar, analizar y recomendar

- Agentes de Security Copilot
- Promptbooks
- Plugins y herramientas (Tools)
- Fuentes de contexto (Grounding)
- Interpretación y clasificación
- Recomendaciones con evidencia

## 2 PLANO DE ORQUESTACIÓN

Controlar el flujo, el estado y las políticas

- Sentinel Automation Rules
- Azure Logic Apps
- Durable Functions / Azure Functions
- Programación y triggers
- Estado, reintentos y manejo de errores
- Aprobaciones y policy gates

## 3 PLANO DE EJECUCIÓN CONTROLADA

Ejecutar acciones determinísticas con mínimo privilegio

- Conectores y APIs
- ITSM / IAM / Sistemas internos
- Sentinel, Defender y otros servicios
- Acciones de remediación y actualización
- Identidades de ejecución dedicadas
- Mínimo privilegio por acción y sistema

## CONTROLES TRANSVERSALES



IDENTIDAD Y PERMISOS



ALLOWLISTS Y POLÍTICAS



VALIDACIÓN Y SCHEMAS



AUDITORÍA Y TRAZABILIDAD



OBSERVABILIDAD Y MÉTRICAS



CONTROL DE COSTOS



ROLLBACK Y RECUPERACIÓN



HUMAN-IN-THE-LOOP



## PRINCIPIO ARQUITECTÓNICO

El agente interpreta. El workflow controla. La identidad autorizada ejecuta. La observabilidad demuestra lo ocurrido. La arquitectura robusta separa responsabilidades.

# No todos sus componentes tienen el mismo estado de disponibilidad.

La disponibilidad de Security Copilot no es uniforme. Debe validarse por componente, región, **tenant**, **workspace**, identidad, trigger y canal.

SERIE DE INFOGRAFÍAS

01 02 03 04 05 06 07 08 09 10

ESTA ES LA INFOGRAFÍA 2 DE 10

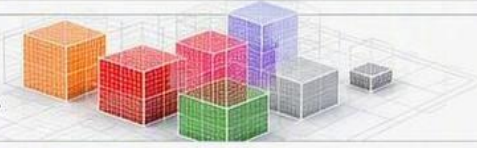
CÓDIGO DE ESTADO

- Documentado / sin aviso general de Preview
- Preview / Prerelease
- Private Preview
- Sujeto a validación del entorno

| CAPACIDAD                                                                                                                                   | ESTADO DOCUMENTADO                                    | RESTRICCIÓN PRINCIPAL                                                                                 | VALIDACIÓN NECESARIA                                                           | IMPLICACIÓN DE ARQUITECTURA                                                                     |
|---------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|-------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
|  <b>Agentes personalizados</b>                             | ● Disponibilidad progresiva; componentes Prerelease   | Capacidad en evolución. Soporte regional, tenant y SLA por validar.                                   | Región, tenant, workspace, soporte productivo y condiciones aplicables.        | No asumir disponibilidad general a partir de una demostración o artículo aislado.               |
|  <b>Agent Builder (formularios)</b>                        | ● Documentación con aviso de Prerelease               | Constructor en evolución.                                                                             | Funcionalidades disponibles en el entorno objetivo.                            | Útil para configuración rápida, generar YAML visible y descargable.                             |
|  <b>Autoría mediante YAML / JSON</b>                       | ● Documentada (partes en Prerelease)                  | Algunas experiencias siguen bajo aviso Prerelease.                                                    | Herramientas de validación, experiencia de publicación.                        | Opción recomendada para control de versiones, revisión y automatización del ciclo de vida.      |
|  <b>Agentes interactivos</b>                             | ● Documentados                                        | Requieren PromptSkill, interfaz InteractiveAgent e input UserRequest.                                 | Plugins requeridos habilitados antes de probar.                                | Habilitan "Chat with agent" con los requisitos indicados.                                       |
|  <b>MCP como plugin de Security Copilot</b>              | ● Preview                                             | Solo se admiten tools. No resources, prompts ni utilities. Sin redescubrimiento dinámico de catálogo. | YAML re-cargado cuando cambian tools. AllowedTools como allowlist obligatoria. | Atractivo para lectura, enriquecimiento y acciones acotadas. No sustituto del gobierno de APIs. |
|  <b>Creación de agentes mediante MCP / NL2Agent</b>      | ● Private Preview disponible globalmente              | Funcionalidad en Private Preview.                                                                     | Disponibilidad en el entorno y cliente MCP compatible.                         | Genera YAML y despliega a usuario o workspace.                                                  |
|  <b>Conector de Security Copilot para Power Platform</b> | ● Preview                                             | Exclusiones en nubes gubernamentales y China.                                                         | Producto, entorno, región y catálogo efectivo de acciones.                     | Conector publicado para Copilot Studio, Power Automate, Power Apps y Logic Apps.                |
|  <b>Invocación de agentes desde Logic Apps</b>           | ● Documentada (sujeta al estado Preview del conector) | Agentes totalmente configurados, compartidos con el workspace y en el default workspace.              | Conector disponible y agentes visibles en el entorno.                          | La identidad de conexión es distinta de la identidad con la que corre el agente.                |
|  <b>Promptbooks</b>                                      | ● Documentada (sin aviso general)                     | Invocación directa de system capabilities en Preview.                                                 | Capacidades específicas habilitadas en el entorno.                             | Adecuados para flujos lineales, parametrizables y repetibles.                                   |
|  <b>Playbooks de Sentinel</b>                            | ● Capacidad estable (basada en Logic Apps)            | Algunos elementos: trigger de alerta y autenticación con managed identity en Preview.                 | Tipo de trigger utilizado y mecanismo de autenticación.                        | Preferir incident trigger y automation rules para producción.                                   |
|  <b>Autotune de instrucciones</b>                        | ● Disponibilidad regional limitada                    | Disponibilidad en Estados Unidos y Europa.                                                            | Verificar disponibilidad regional antes de utilizar.                           | No disponible en todas las regiones.                                                            |



**IMPLICACIÓN CLAVE**  
Construya una matriz de disponibilidad por componente: runtime, método de autoría, herramienta, conector, identidad, trigger, región y portal.



- NOTAS**
- El estado puede variar por producto, entorno y región.
  - No extrapolar disponibilidad general desde demostraciones o artículos aislados.
  - Verifique actualizaciones en la documentación oficial de Microsoft Security.



- REFERENCIAS PRINCIPALES**
- Security Copilot Agent Development Overview | Microsoft Learn
  - Microsoft Security Copilot – Connectors | Microsoft Learn
  - Trigger Security Copilot agents from Azure Logic Apps | Microsoft Learn
  - Sentinel automation rules | Microsoft Learn
  - Model Context Protocol (MCP) plugins (Preview) | Microsoft Learn

## SERIE DE INFOGRAFÍAS

01 02 03 04 05 06 07 08 09 10

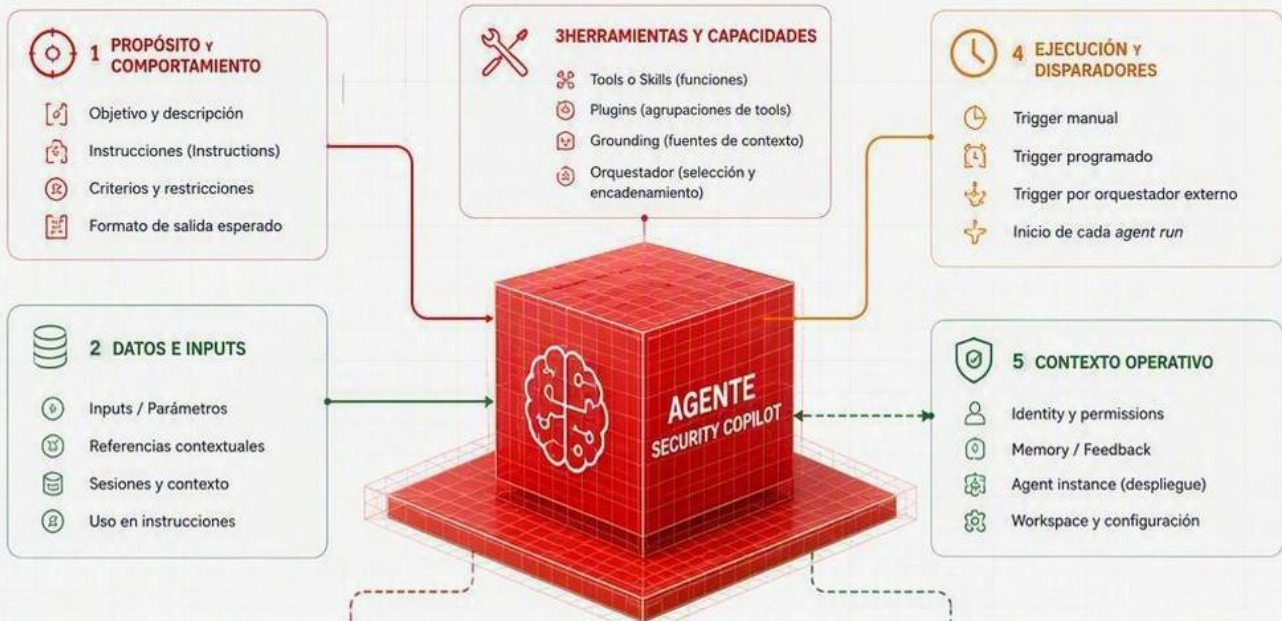
ESTA ES LA INFOGRAFÍA 3 DE 10

## LECTURA SUGERIDA

→ Relación principal  
 - - - - - Relación opcional / condicional

# El agente posee una arquitectura y un contrato explícitos.

Un agente de Security Copilot combina instrucciones, herramientas, contexto, disparadores e identidad. El manifiesto YAML/JSON es el contrato que define qué puede hacer, qué necesita y bajo qué condiciones se ejecuta.



## PATRONES DE SELECCIÓN DE HERRAMIENTAS

## SELECCIÓN ESTÁTICA



- Conjunto de tools declarado explícitamente.
- Menor ambigüedad y latencia.
- Superficie de riesgo reducida.
- Mayor predictibilidad.



## SELECCIÓN DINÁMICA



- El agente elige tools según contexto, razonamiento e inputs.
- Mayor flexibilidad.
- Mayor superficie de prueba.
- Riesgo de seleccionar una acción incorrecta.

## EL MANIFIESTO COMO CONTRATO DE EJECUCIÓN

Definición declarativa en YAML o JSON que describe al agente, sus dependencias, herramientas, entradas, disparadores y restricciones.



Debe existir al menos un trigger.

ProcessSkill es obligatorio.

FetchSkill es opcional: obtiene una colección de objetos y ejecuta ProcessSkill por cada elemento.



## ATENCIÓN

El trigger nativo no impide por sí mismo ejecuciones concurrentes. Las restricciones de instancia no son un bloqueo transaccional de runs. Para procesos no idempotentes, implementar controles externos de exclusión, deduplicación y gestión de estado.



Exclusión mutua



Deduplicación de eventos



Estado persistente



Idempotencia de acciones



Control de concurrencia



## NOTA

El manifiesto se valida al publicar la definición en el workspace, pero las validaciones automáticas no sustituyen las pruebas funcionales, de seguridad y de resiliencia.

# Las tools amplían capacidad y riesgo.

Las tools y plugins conectan el agente con datos y sistemas externos. Cada formato tiene usos adecuados y riesgos que deben controlarse mediante allowlists, contratos y políticas de autorización.

## SERIE DE INFOGRAFÍAS

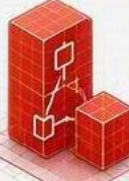
01 02 03 **04** 05 06 07 08 09 10

ESTA ES LA INFOGRAFÍA 4 DE 10

## CÓDIGO DE RIESGO

- Riesgo bajo
- Riesgo medio
- Riesgo alto

## FORMATOS PRINCIPALES DE TOOLS EN SECURITY COPILOT

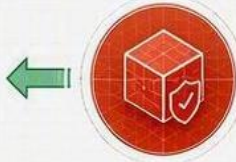
| KQL                                                                                                                                                                          | API                                                                                                                                                                                   | GPT                                                                                                                                                         | AGENT                                                                                                                                                                               | MCP                                                                                                                                                                                                 | LOGIC APP                                                                                                                                                                                        |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                             |                                                                                                      |                                                                            |                                                                                                    |                                                                                                                  |                                                                                                               |
| <b>USO APROPIADO</b> <ul style="list-style-type: none"><li>Consultar Sentinel</li><li>Consultar Defender</li><li>Recuperar incidentes</li><li>Señales y eventos</li></ul>    | <b>USO APROPIADO</b> <ul style="list-style-type: none"><li>Integrar CMDB, ITSM IAM y servicios internos</li><li>Servicios externos</li></ul>                                          | <b>USO APROPIADO</b> <ul style="list-style-type: none"><li>Clasificación</li><li>Extracción</li><li>Normalización</li><li>Generación estructurada</li></ul> | <b>USO APROPIADO</b> <ul style="list-style-type: none"><li>Planificación multi-step</li><li>Encadenamiento</li><li>Escenarios multiagente</li><li>Decisiones contextuales</li></ul> | <b>USO APROPIADO</b> <ul style="list-style-type: none"><li>Descubrimiento de tools desde un servidor MCP</li><li>Lectura y enriquecimiento</li><li>Acciones acotadas</li></ul>                      | <b>USO APROPIADO</b> <ul style="list-style-type: none"><li>Ejecutar un workflow gobernado</li><li>Crear tickets, notificar</li><li>Actualizar incidentes</li><li>Iniciar remediaciones</li></ul> |
| <b>RIESGOS PRINCIPALES</b> <ul style="list-style-type: none"><li>Consultas costosas</li><li>Resultados demasiado amplios</li><li>Datos insuficientemente filtrados</li></ul> | <b>RIESGOS PRINCIPALES</b> <ul style="list-style-type: none"><li>Autenticación</li><li>Exfiltración de datos</li><li>Cambios no idempotentes</li><li>Esquemas incompatibles</li></ul> | <b>RIESGOS PRINCIPALES</b> <ul style="list-style-type: none"><li>Alucinación</li><li>Falta de grounding</li><li>Formatos inválidos</li></ul>                | <b>RIESGOS PRINCIPALES</b> <ul style="list-style-type: none"><li>Loops</li><li>Mayor complejidad</li><li>Mayor consumo</li><li>Menor predictibilidad</li></ul>                      | <b>RIESGOS PRINCIPALES</b> <ul style="list-style-type: none"><li>Confianza en el servidor</li><li>Catálogo cambiante</li><li>Superficie de cadena de suministro</li><li>Datos de terceros</li></ul> | <b>RIESGOS PRINCIPALES</b> <ul style="list-style-type: none"><li>Exposición del trigger</li><li>Secretos y privilegios</li><li>Costos de acciones</li><li>Efectos externos</li></ul>             |

## REGLAS DE SELECCIÓN Y CONTROL



## LECTURA Y GROUNDING

- Selección dinámica dentro de una allowlist
- Acceso mínimo necesario
- Resultados filtrados y con contexto
- Validación de salida



## ESCRITURA Y REMEDIACIÓN

- Selección estática (tools explícitas)
- Parámetros validados y esquema controlado
- Aprobación humana o policy gate
- Idempotencia y registro de acciones



Las tools con efectos sobre sistemas externos requieren controles adicionales de autorización, aprobación y auditoría.



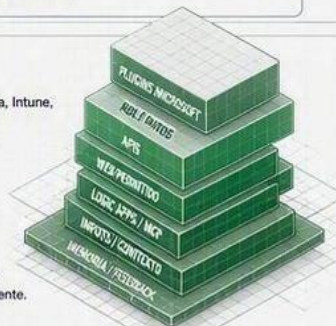
## MCP: CONSIDERACIONES ACTUALES (PREVIEW)

- Solo se importan tools. No resources, prompts ni utilities.
- AllowedTools es obligatorio (allowlist).
- No hay actualización automática del catálogo de herramientas.
- Tools con destructiveHint=true no se importan.
- Inputs con tipos primitivos únicamente.
- Se recomienda Streamable HTTP; SSE previsto deprecado.
- La responsabilidad por servidores y datos no Microsoft recae en la organización.



## FUENTES DE GROUNDING

- Plugins Microsoft: Sentinel, Defender, Entra, Intune, Purview, Threat Intelligence.
- KQL sobre datos organizacionales.
- APIs internas o externas.
- Sitios web permitidos.
- Datos recuperados por Logic Apps.
- Herramientas MCP.
- Inputs y contexto aportados por sesiones.
- Memoria y feedback de la instancia del agente.



## PIPELINE DE HABILITACIÓN DE TOOLS



Revisar y retirar herramientas que no cumplan con su propósito o generen riesgo indebido.

## ADVERTENCIA OPERATIVA



Una tool mal seleccionada o mal configurada puede exponer **datos**, generar acciones **no deseadas** o incrementar costos. Gobernar antes de habilitar.

## SERIE DE INFOGRAFÍAS

01 02 03 05 06 07 08 09 10

ESTA ES LA INFOGRAFÍA 5 DE 10

## LECTURA SUGERIDA

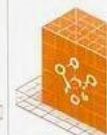
→ Relación principal

- - - → Relación opcional / condicional

# El agente no reemplaza todos los mecanismos de automatización.

Cada mecanismo tiene un propósito específico. La elección correcta depende de la variabilidad del trabajo, la necesidad de estado y el nivel de determinismo requerido.

## MECANISMOS DE AUTOMATIZACIÓN EN EL ECOSISTEMA DE MICROSOFT SECURITY

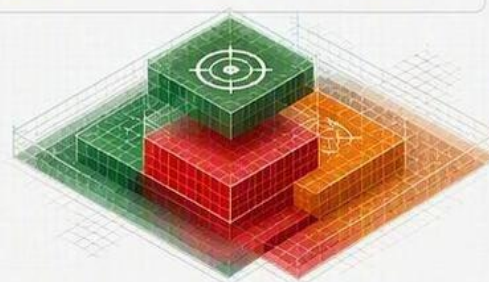
|                        | PROMPT INDIVIDUAL                                                                 | PROMPTBOOK                                                                        | AGENTE DE SECURITY COPILOT                                                        | PLAYBOOK DE SENTINEL (LOGIC APPS)                                                 | AZURE AUTOMATION RUNBOOK                                                           | DURABLE FUNCTIONS                                                                   | CONTAINER APPS JOB                                                                  |
|------------------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|
|                        |  |  |  |  |  |  |  |
| NATURALEZA             | Interacción puntual                                                               | Secuencia lineal de prompts                                                       | Planificador con herramientas (tools)                                             | Workflow de Logic Apps                                                            | Código PowerShell / Python                                                         | Orquestación serverless codificada                                                  | Proceso contenedorizado finito                                                      |
| DETERMINISMO           | Bajo                                                                              | Medio                                                                             | Variable                                                                          | Alto                                                                              | Alto                                                                               | Alto                                                                                | Alto                                                                                |
| ESTADO                 | Ninguno                                                                           | Respuestas previas de la misma secuencia                                          | Inputs, run, memoria y feedback                                                   | Estado del workflow                                                               | Estado del job                                                                     | Estado durable y checkpoints                                                        | Estado de ejecución                                                                 |
| ADAPTACIÓN AL CONTEXTO | Muy baja                                                                          | Baja                                                                              | Alta (planifica y selecciona tools)                                               | Baja                                                                              | Muy baja (código fijo)                                                             | Media (lógica definida por código)                                                  | Muy baja (ejecución fija)                                                           |
| MEJOR USO              | Investigación ad hoc                                                              | Investigación estandarizada y repetible                                           | Investigación adaptable, clasificación y decisiones contextuales                  | Respuesta SOAR, orquestación y automatización conectada                           | Administración, tareas operativas y mantenimiento                                  | Procesos largos, fan-out/fan-in, recuperación y coordinación                        | Batch, dependencias complejas, workloads personalizados                             |

## GUÍA DE DECISIÓN RÁPIDA



## PRINCIPIOS DE SELECCIÓN

|                                                                                                                                                                                  |                                                                                                                                                                                     |                                                                                                                                                                                         |                                                                                                                                                                                             |                                                                                                                                                                                                            |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <br>Menor complejidad posible<br>Comience con el mecanismo más simple que cumpla el objetivo. | <br>Determinismo donde importa<br>Las acciones que cambian el entorno deben ser determinísticas. | <br>Separación de responsabilidades<br>El agente razona. El workflow controla. La identidad ejecuta. | <br>Estado y recuperación explícitos<br>Use mecanismos con estado cuando el proceso sea largo o crítico. | <br>Observabilidad y costo<br>Elija el mecanismo que mejore el valor operativo con el menor riesgo y consumo razonable. |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|



## NOTAS IMPORTANTES

- Un agente no sustituye a un workflow determinístico.
- Para acciones de alto impacto, mantenga aprobación humana o policy gate.
- Cada mecanismo tiene límites técnicos y operativos propios.
- Evalúe también identidad, permisos, conectores y capacidad disponible.

## EJEMPLOS DE TRABAJO

- Investigación adaptable → Agente
- Flujo de respuesta a incidente → Playbook de Sentinel
- Enriquecimiento periódico → Logic Apps / Automation Runbook
- Procesamiento masivo → Durable Functions / Container Apps Job

## LEYENDA DE COLORES

- Interacción y lectura
- Razonamiento y decisión
- Orquestación y ejecución
- Infraestructura / código

## SERIE DE INFOGRAFÍAS

01 02 03 04 06 06 08 09 10

ESTA ES LA INFOGRAFÍA 6 DE 10

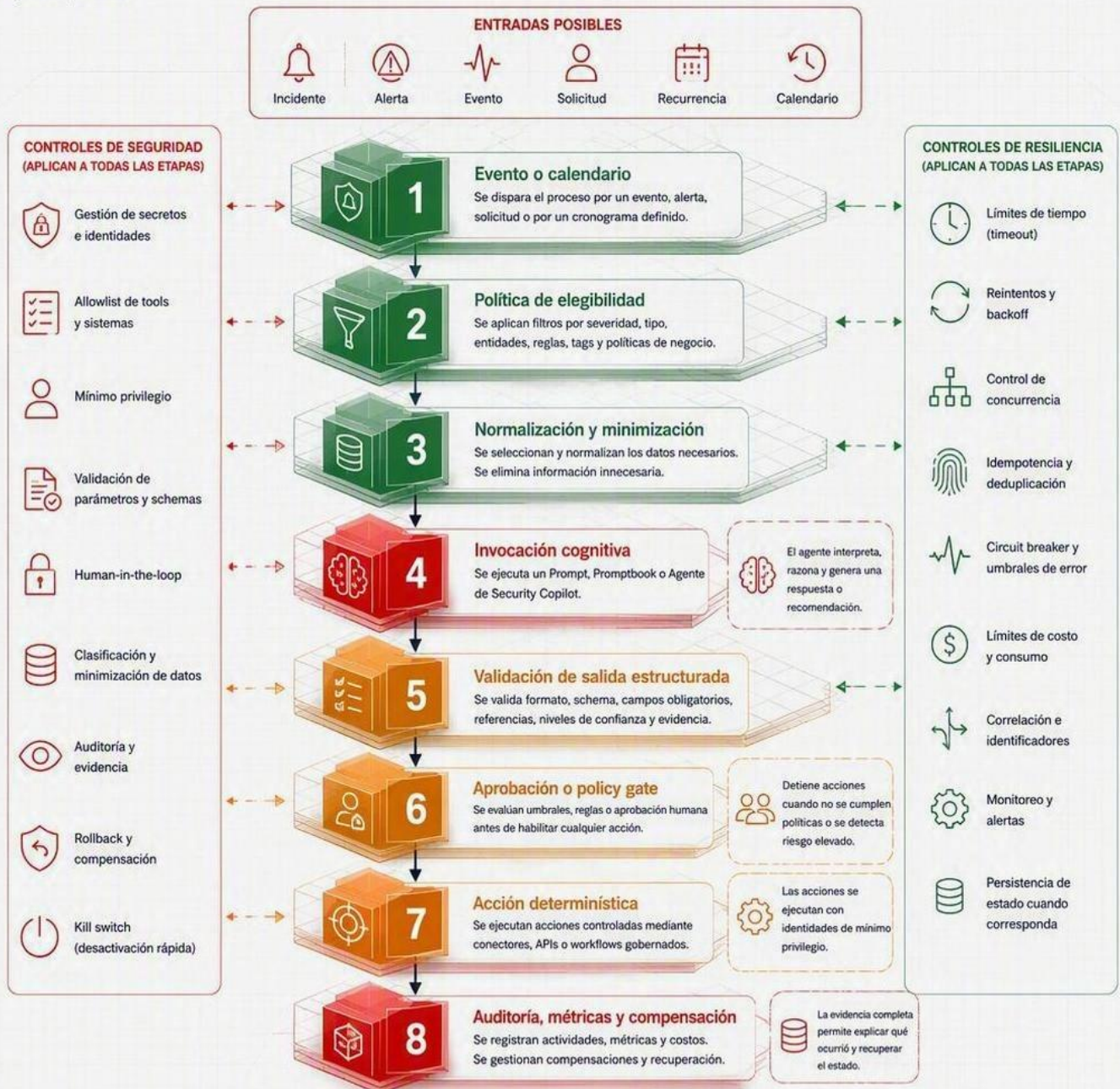
## LECTURA SUGERIDA

→ Flujo principal (secuencia)

- - -&gt; Controles transversales (aplican a todas las etapas)

# El arnés aporta las garantías operativas.

El arnés es la capa de ingeniería que rodea al agente y convierte la capacidad generativa en un servicio operable, seguro, auditable y recuperable.



## PRINCIPIOS DEL ARNÉS



No delegar al LLM las garantías propias de un motor transaccional.



Separar interpretación (probabilística) de ejecución (determinística).



Validar antes de actuar.



Aplicar mínimo privilegio en cada sistema destino.



Trazabilidad completa de extremo a extremo.



Diseñar para recuperación y reversión.



## ATENCIÓN

Las restricciones de instancia del agente no impiden, por sí mismas, ejecuciones concurrentes. Para procesos no idempotentes, implemente controles externos de exclusión, deduplicación y estado.

## IMPLEMENTACIONES HABITUALES



Azure Logic Apps



Durable Functions



Azure Functions



Azure Automation



Aplicación propia

# Sentinel y Logic Apps integran la IA dentro del SOAR.

El razonamiento del agente se ejecuta dentro de un workflow controlado que filtra, valida, aprueba y ejecuta acciones determinísticas sobre los sistemas.

## SERIE DE INFOGRAFÍAS

01 02 03 05 06 07 08 09 10

ESTA ES LA INFOGRAFÍA 7 DE 10

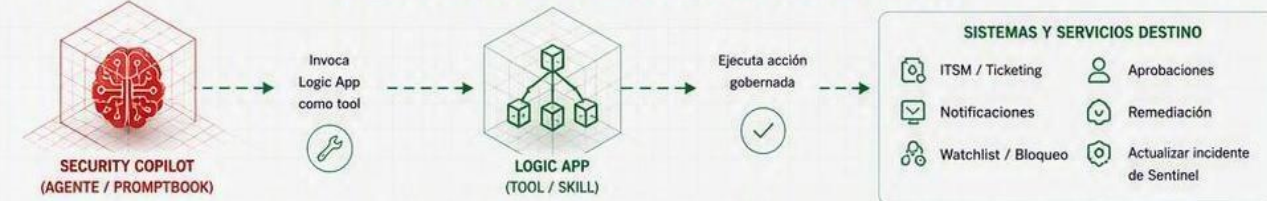
## LECTURA SUGERIDA

→ Relación principal (flujo)  
- - - - - Relación opcional / inversa

## PATRÓN PRINCIPAL: INCIDENTE → IA → CONTROL → REMEDIACIÓN



## INTEGRACIÓN INVERSA: SECURITY COPILOT → LOGIC APP COMO TOOL



## REQUISITOS PARA QUE EL AGENTE APAREZCA EN LOGIC APPS

- ☒ Agente completamente configurado
- ☒ Publicado para "Anyone in this workspace"
- ☒ Compartido con el workspace
- ☒ Ubicado en el default workspace



## CONTROLES CLAVE EN EL WORKFLOW

- ☒ Validación de entradas y salidas
- ☒ Límites de tiempo y reintentos
- ☒ Deduplicación e idempotencia
- ☒ Aprobación humana (cuando aplique)
- ☒ Allowlist de acciones permitidas
- ☒ Registro y auditoría de cada ejecución
- ☒ Rollback y compensación definidos



## EJEMPLOS DE ACCIONES GOBERNADAS

- ☒ Crear o actualizar tickets
- ☒ Enviar notificaciones
- ☒ Agregar entidad a watchlist
- ☒ Iniciar remediación aprobada
- ☒ Solicitar aprobación
- ☒ Actualizar incidente de Sentinel

## BENEFICIOS DEL PATRÓN

- ☒ Separa razonamiento (IA) de ejecución (determinística).
- ☒ Proporciona control, auditoría y recuperación.
- ☒ Reduce riesgo de acciones no intencionadas.
- ☒ Permite aplicar políticas y aprobaciones antes de modificar entornos.



## ATENCIÓN

-  No todos los triggers de alerta están disponibles para Automation Rules; validar en el entorno.
-  Algunos elementos de autenticación y triggers permanecen en Preview.
-  Verificar disponibilidad efectiva por tenant, región y workspace.



RESULTADO: IA PARA INTERPRETAR, WORKFLOWS PARA CONTROLAR, IDENTIDADES PARA EJECUTAR, AUDITORÍA PARA EXPLICAR.

# La identidad determina qué puede consultar y ejecutar cada componente.

Una ejecución puede involucrar varias identidades y planos de autorización.

Los permisos no se heredan automáticamente entre planos o sistemas.

## SERIE DE INFOGRAFÍAS

01 02 04 05 06 07 **08** 09 10

ESTA ES LA INFOGRAFÍA 8 DE 10

## LECTURA SUGERIDA

- Relación principal (uso / autorización)  
 - - - - - Relación condicional / opcional



## PLANO DE AUTORIZACIÓN SECURITY COPILOT RBAC

Controla el acceso a la plataforma Security Copilot y a sus recursos.



### Owner

Administración completa de workspaces, plugins, configuración y publicación.



### Contributor

Puede usar la plataforma, crear y editar recursos según permisos otorgados.

No implica acceso automático a datos o sistemas subyacentes.



## PLANO DE AUTORIZACIÓN MICROSOFT ENTRA Y RBAC DE PRODUCTO

Determina qué datos y acciones puede realizar la identidad en cada producto.



Microsoft Sentinel



Microsoft Defender



Microsoft Entra ID



Microsoft Intune



Microsoft Purview



Threat Intelligence

Security Copilot usa los permisos de la identidad. No eleva privilegios en el backend.



## PLANO DE AUTORIZACIÓN AZURE RBAC

Controla el acceso a los recursos de Azure que soportan la solución.



Azure Logic Apps



Workspaces y recursos (Sentinel, Log Analytics, Storage)



Capacidad SCU (provisionada y overage)



Funciones, Automation, Container Apps y otros servicios

Permite crear, ejecutar y administrar recursos de Azure.

### IDENTIDADES INVOLUCRADAS EN UNA EJECUCIÓN



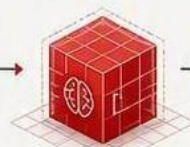
**IDENTIDAD A**  
Conexión de Logic Apps a Security Copilot



Las guías específicas indican OAuth delegado.  
 No necesariamente es la misma identidad que ejecuta el agente.



**IDENTIDAD B**  
Identity del agent run



Configurada en el agente. Puede ser una identidad dedicada\* (agentes Microsoft-built) o una cuenta existente (agentes personalizados).



**IDENTIDAD C**  
Conexión de Logic Apps a Sentinel u otros sistemas



Puede usar Managed Identity\*\*, Service Principal o Usuario, según el conector y el sistema.



**IDENTIDAD D**  
Identity de remediación (ejecución de acciones)



Usada para ejecutar acciones sobre sistemas de destino (ITSM, IAM, endpoints, tickets, etc.). Debe operar con mínimo privilegio.



### INCONSISTENCIA DOCUMENTAL IMPORTANTE

La referencia general del conector de Security Copilot menciona autenticación mediante Service Principal.



Las guías específicas de Logic Apps y Copilot Studio describen únicamente OAuth delegado.



### IMPLICACIÓN DE DISEÑO

No asumir soporte de Managed Identity o application-only para llamar a Security Copilot sin validación efectiva en el entorno y región.

### EJEMPLO: UN FLUJO, VARIAS IDENTIDADES



**A**  
Automation Rule de Sentinel dispara el playbook



**B**  
Logic App se conecta a Security Copilot



**B**  
El agente se ejecuta con la Identity B y accede a datos según permisos



**C**  
Logic App usa la Identity C para consultar o actualizar Sentinel



**D**  
Logic App ejecuta la remediación con la Identity D sobre el sistema destino

### PRINCIPIOS CLAVE

- Separación de identidades entre acceso a la IA, acceso a datos y ejecución de remediación.
- Mínimo privilegio por sistema y por acción.
- Verificar permisos en cada plano antes de asumir capacidad de consulta o ejecución.
- Registrar y correlacionar qué identidad realizó cada operación.



#### NOTAS

- \* Identity dedicada basada en Microsoft Entra Agent ID: documentada actualmente solo para agentes Microsoft-built.
- \*\* Managed Identity para conectores (ej. Sentinel): documentada como Preview.

#### LEYENDA

- Uso / autorización
- - - - - Relación condicional o sujeta a validación



#### RECUERDE

Estar autorizado en Security Copilot no implica acceso automático a los datos de seguridad ni permite ejecutar remediaciones.

# Testing, observabilidad y costos permiten operar con evidencia.

Publicar un agente no equivale a validarlo. La operación exige evidencia de calidad, seguridad, resiliencia, trazabilidad y consumo.

## SERIE DE INFOGRAFÍAS

01 02 03 04 05 06 07 09 10

ESTA ES LA INFOGRAFÍA 9 DE 10

## LECTURA SUGERIDA

- Relación principal (flujo de datos)
- > Relación de soporte / contexto

## 1 CALIDAD Y TESTING

Asegurar que el agente y sus tools generan resultados correctos y útiles.

## PRUEBAS DE TOOLS



- Contratos de inputs y outputs
- Schemas y formatos JSON
- Autenticación y permisos
- Timeouts y códigos de error
- Respuestas ante fallos (4xx/5xx)

## EVALUACIÓN DEL RAZONAMIENTO



- Conjunto dorado de incidentes
- Resultados esperados
- Precisión de clasificación
- Complejidad de evidencias
- Llamadas innecesarias

## SEGURIDAD



- Prompt injection
- Datos sensibles
- Tool poisoning
- Bypass de allowlists
- Permisos insuficientes o excesivos

## RESILIENCIA



429 / Throttling



403 / Forbidden



5xx / Timeouts



Duplicados



Caída de plugin



JSONi



Ejecución concurrente

## ESTRATEGIA DE PRODUCCIÓN CONTROLADA

1

Read-only

2

Shadow mode sin remediación

3

Canary por tipo de incidente

4

Aprobación humana

5

Rollback con manifiesto versionado

## 2 OBSERVABILIDAD Y AUDITORÍA

Ver, entender y explicar cada ejecución de extremo a extremo.

## TELEMETRÍA DE SECURITY COPILOT

- Session ID
- SCUs consumidas
- Iniciador (usuario / sistema / workflow)
- Categoría (prompt / promptbook / agent / primitive)
- Manual o automatizado
- Experiencia de origen
- Plugins utilizados
- Estado (éxito / error / cancelado)

## AUDITORÍA Y CUMPLIMIENTO



Microsoft Purview Unified Audit Log

- Acciones administrativas
- Metadatos de actividad



Microsoft Purview DSPM for AI

- Contenido de prompts y respuestas



Office Management API

- Eventos y reportes de auditoría

## OBSERVABILIDAD DE LOGIC APPS



Historial de triggers y runs



Inputs, Outputs y estados



Errores y reintentos



Correlation ID



Alertas y métricas



Acceso controlado por RBAC

## EXPORTACIÓN Y ANÁLISIS



Excel / Reportes



Log Analytics



Azure Monitor



Application Insights

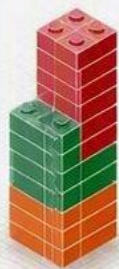


Dashboards y alertas

## 3 COSTOS Y CAPACIDAD

Comprender cómo se consume y qué otros servicios generan costo.

## SECURITY COPILOT (SCUs)



- Provisioned capacity**  
Mínimo de 1 SCU.  
Facturación por bloque horario completo.
- Overage**  
Consumo adicional medido hasta décimas de SCU.  
Límite configurable o ilimitado.
- Incluidas (E5 / E7)**  
400 SCUs mensuales por cada 1.000 licencias pagas (hasta 10.000 SCUs).  
No se acumulan entre meses.

## OTROS COSTOS POTENCIALES



Azure Logic Apps (Consumption o Standard)



Microsoft Sentinel / Log Analytics / Data Lake



Azure Functions / Durable Functions



Azure Automation



Azure Container Apps Jobs



APIs externas y fuentes de datos



Licencias de partners y plugins



Productos necesarios por una tool

## LÍMITES OPERATIVOS

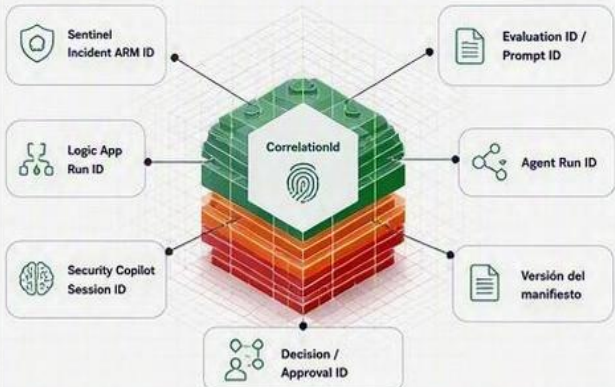


Límite publicado del conector:  
600 llamadas por conexión cada 60 segundos.

Gestionar junto con capacidad SCU y límites del sistema consultado.

## 4 CORRELACIÓN Y TRAZABILIDAD

Un identificador común conecta todo el recorrido.



Permite explicar qué evento inició la operación, qué decisiones tomó el agente, qué herramientas usó, qué identidad ejecutó y qué acción final se aplicó.

## PRÁCTICAS RECOMENDADAS



Registrar antes que ejecutar



Validar salidas antes de actuar



Principio de mínimo privilegio



Monitorear calidad y consumo



Definir umbrales y alertas



Documentar y retener evidencias



Probar fallos y recuperación



Revisar costos periódicamente



## ATENCIÓN

- Sin correlación, no hay trazabilidad.
- Sin métricas, no hay mejora.
- Sin límites, no hay control de costos.



## RECUERDE

- Probar no consume SCUs en Private Preview.
- Probar y ejecutar si consume capacidad en GA y Preview.
- La capacidad no utilizada expira al final de cada hora.



## NOTA

Los resource logs de Azure pueden presentar latencia de varios minutos. No son completamente lossless. No usarlos como única fuente crítica.

# La adopción debe progresar desde lectura hacia acción gobernada.

Comenzar con escenarios de bajo riesgo y avanzar con evidencia, controles y aprobación. El objetivo es generar valor medible de manera segura, auditable y recuperable.

## SERIE DE INFOGRAFÍAS

01 02 03 04 05 06 07 08 09 10

ESTA ES LA INFOGRAFÍA 10 DE 10

## LECTURA SUGERIDA

→ Relación principal (progresión)

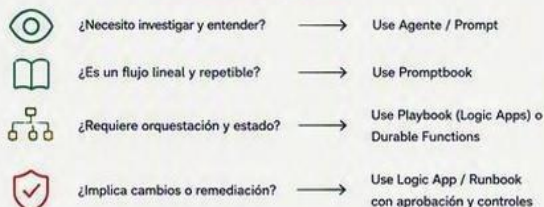
---→ Relación opcional / transversal



## GOBIERNO TRANSVERSAL EN TODAS LAS ETAPAS



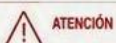
## GUÍA RÁPIDA DE DECISIÓN



## SEPARACIÓN DE IDENTIDADES (PRINCIPIO)

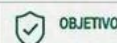


## RECOMENDACIONES CLAVE



## ATENCIÓN

Algunas capacidades se encuentran en Preview o Private Preview. Valide disponibilidad efectiva en su tenant, región, workspace y canal antes de producción.



## OBJETIVO

Generar valor operativo con controles verificables, trazabilidad completa y capacidad de recuperación.